

Security & Access Document

PrepFlow — Hybrid AI Exam Practice & Progress Tracker

1. Security objectives

- Only authenticated users access their accounts.
- Users access only their own books, questions, attempts, analytics, and exports.
- Original books remain private; no permanent public URLs.
- Answer keys remain server-side until a valid answer submission.
- API keys and administrator credentials are never exposed to browsers.
- Users can delete books and associated retrieval/index data.

2. Authentication

Use Supabase Auth with email/password, email verification, password reset, secure HTTP-only sessions, and rate-limited login/reset endpoints. Require reauthentication for book deletion, account deletion, and complete data export.

3. Roles and permissions

Capability	Guest	Regular user	Administrator
Public pages/signup	Yes	Yes	Yes
Upload/view/delete own books	No	Yes	No by default
Practice and analytics	No	Own data only	No by default
Read another user's content	No	No	No by default
Operational aggregate metrics	No	No	Yes
Retry processing jobs	No	Own retry only	Yes
Platform configuration	No	No	Yes

4. Administrator access principle

Administrators are platform operators, not default readers of private books or study history. Any exceptional support access requires explicit user consent, a time limit, least-privilege scope, and an audit-log record.

5. Row-level security

Enable RLS on every public user-data table. The ownership rule is ``user_id = auth.uid()``. Users may read/write only their own profiles, exams, books, sessions, attempts, goals, and revisions. Questions are visible only through ready books owned by the authenticated user. Processing jobs and sensitive writes occur through controlled server-side code.

6. Storage security

Use a private ``books`` bucket. Object paths must be user scoped, for example ``books/{auth.uid()}/{book_id}/original.pdf``. Permit users to upload/list/read/delete only their own folder. Use short-lived signed URLs. Do not make the bucket public.

7. API rules

- Authenticate every endpoint and derive the user ID from the trusted server session.
- Verify resource ownership for every book, question, session, and export ID.
- Validate payloads with Zod.
- Rate-limit login, reset, upload, AI generation, hints, and costly endpoints.
- Use idempotency keys for answer submissions.
- Return only fields permitted at the current state; never send answer keys before submission.
- Audit sensitive actions.

8. Answer-key protection

Before submission, return only question text, A-D options, sequence/progress, and safe metadata. Store `correct\_option` and detailed explanation server-side. After server scoring, return result, correct option, explanation, and source reference.

9. File upload security

- Allow PDF, DOCX, and TXT initially.
- Validate filename extension and MIME type on server.
- Use a defined file-size limit and reject encrypted/password-protected content for MVP.
- Generate storage paths server-side; do not trust user filenames.
- Reject executables, archives, scripts, and HTML.
- Use malware scanning in production where feasible.
- Require a statement that the user is authorized to upload and use the material.

10. Error handling

Failure	User message	System action
Invalid login	Email or password is incorrect.	Rate-limit and log safe event
Unsupported/large file	Upload a supported file within the size limit.	Reject before processing
Unreadable document	We could not read this file clearly.	Mark job failed; allow retry
Uncertain classification	Choose Question Bank, Theory, or Mixed.	Require user confirmation
No reliable answer key	Questions found but answer key is not reliable.	Flag for review; avoid authoritative scoring
AI failure	We could not create a question right now.	No partial save; retry safely
Duplicate answer submit	Your answer has already been saved.	Return prior result
Unauthorized request	You do not have access to this item.	Return 403 without leakage

11. Important edge cases

- Refresh or duplicate submit during a slow answer request.
- Same question open in two tabs.
- Skip/unsure/revision must not incorrectly advance primary sequence.
- Practice across midnight must honor the user timezone.
- Scanned, mixed-language, password-protected, malformed, or duplicate PDFs.
- Answer key at book end, duplicate numbering, multi-line options, or missing options.

- User changes active book during a session.
- Book deletion while background processing is still running.
- Attempts to alter IDs in browser requests or guess storage paths.

12. Privacy and retention

Collect only account, exam, book, practice, and operational data needed to run the app. Do not use user study content to train custom models by default. On book/account deletion, queue removal of storage objects, metadata, extracted/generated questions, related retrieval resources, and permitted analytics/attempt data under a clear retention policy.